北京信达 主机加固
www.s-numen.com

中图分类号: TP393.08　文献标志码: B　文章编号: 2095-641X(2018)12-0051-05　DOI: 10.16543/j.2095-641x.electric.power.ict.2018.12.009
著录格式: 李凌 , 郭旭 , 李琳 . 云计算服务产品的评估体系研究 [J]. 电力信息与通信技术 , 2018, 16(12): 51-55.

云计算服务产品的评估体系研究

李凌，郭旭，李琳
（中国电力科学研究院有限公司 信息通信研究所，北京 100192）

Research on Evaluation System of Cloud Computing Services Products

LI Ling, GUO Xu, LI Lin
(Information Communication Department, China Electric Power Research Institute, Beijing 100192, China)

摘要: 在云计算服务产品广泛发展的背景下，文章立足其当前发展水平，首先分析了目前云计算服务产品所面临的安全性问题；其次，对国内外有关云计算服务产品环境安全检查、评估的发展与研究现状进行了较为详细的介绍，通过对已有研究的深刻理解，建立了一套可用于云计算服务产品的评估模型；最后，基于该模型对 4 家云服务商的产品进行测试、评分，并给出对比结论与建议。

关键词: 云计算服务；安全检查；评估模型

Abstract: With the wide development of cloud computing services, this paper discusses security issues in the background of today's cloud computing services environment. And the domestic and international trends of the security check and evaluation model is discussed in detail about the cloud computing services environment. Based on existing research and previous literatures, an effective evaluation model is established in the cloud computing services framework. Finally, by means of this model, the products of 4 cloud service providers are tested and scored, and some guiding comments and suggestions are given.

Key words: cloud computing services; security check; evaluation model

0　引言

自 2006 年 8 月 9 日谷歌总裁 Eric Schmidt 首次在搜索引擎会议上提出云计算概念以来，因云计算可以将大量计算资源统一整合，远离用户进行计算，具有成本低、通用性高、可扩展、服务灵活的特点，已经在各行各业中逐步形成并得到了广泛的推广和应用，同时这些行业部门也在享受云计算服务所带来的各种便利，例如金融、铁路、电力、电信、传媒等 [1] 国家重点信息化部门。但是，在云计算服务产品的发展过程中，由于云计算本身的虚拟化、资源共享、分布式等特点，决定了其不可避免需要面临用户信息资产安全及隐私带来的安全性问题的威胁与考验，例如，存储在云端的数据如何保证其是安全的、个人或者国家的隐私如何不被泄露、对于外界的病毒攻击能否保证信息不被窃取等。然而目前，无论是国内还是国外仍然没有一个完整的、成体系的云计算服务产品的信息系统安全检查与评估标准，并且各大云计算环境发生的安全性问题屡见不鲜，如微软云服务 2 次大规模中断、谷歌 Gmail 电子邮箱爆发全球性故障、Windows Azure 云存储服务出现高达 11 h 的故障、Rackspace 遭受严重的云服务中断故障等。基于以上叙述，建立一套可以用于云计算服务产品的评估体系是十分必要的。

本文首先针对云计算服务产品安全检查与评估的国内外现状进行了深入分析，提出了一套可用于云计算服务产品的评估模型，并基于该模型对 4 家云服务商（分别以 A、B、C、D 简称这 4 家云服务商）的产品进行测试，并根据评估结果给出意见与建议。

(C)1994-2019 China Academic Journal Electronic Publishing House. All rights reserved.　http://www.cnki.net

1 国内外研究现状

由于缺少云计算服务产品相关的安全检查与评估指导，使得云计算服务自出现以来出现了很多安全性问题，这些问题引起了业界人士的广泛关注，也让更多的人意识到对云计算服务产品的安全性研究与评估体系是十分紧迫的，该部分给出相关人士的研究现状。

1.1 国内研究现状

全国信息安全标准化技术委员会组织制定了名为《信息安全技术云计算服务安全指南》和《信息安全技术云计算服务安全能力要求》2 项国家标准，针对云计算的安全性给出了指导性建议 [2-3]；国家信息中心章恒等人给出了一套较为完整的针对云计算环境的安全检查与评估指标体系方案 [4]；吴齐跃等人给出了在云计算环境下信息安全的等级，同时对如何判断云服务的安全性给出了一系列建议 [5]；王希忠等人对云计算环境下信息安全等级保护测评所面临的问题进行了分析，并对当前的测评给出参考建议 [6]；刘明焕通过分析云计算环境面临的风险问题，提出了一种风险评估模型，对提升安全服务的管理水平和风险管控都具有重要意义 [7]；沈余锋等人提出了云计算环境中的虚拟化安全风险的方案，并对目前其存在的问题进行深入的探讨 [8]；曲延盛等人研究了在云计算环境中旁路攻击的安全威胁问题，并给出一套解决模型 [9]；冯扬在分析云计算存在的安全问题的基础上，给出提高云计算可用性、可靠性、隐私性等安全方面的方案 [10]。

1.2 国外研究现状

Gartner 于 2008 年发布题为《评估云计算的安全风险》的报告，报告中指出了目前云计算存在的特权用户接入风险、可审查性风险、数据位置风险、数据隔离风险、数据恢复风险、调查指出风险和长期生存性风险 7 个方面的安全风险 [11]。CSA（Cloud Security Alliance）完成《云计算面临的严重威胁》、《云控制矩阵》等有关安全威胁方面的相关研究报告，主要针对云计算安全的焦点问题进行研究 [12-14]。ENISA（European Network and Information Security Agency）给出一种手段，当企业把数据放到云计算服务器计算时，可有效地降低安全风险，同时也对比了各家云服务供应商的安全水平。NIST（National Institute of Standards and Technology）发布了云计算安全的相关标准，为云计算安全及隐私提供了一些建议和保护措施 [15-16]。

总的来说，国内外的研究虽然都对云计算服务安全性给出了相关建议和策略，也取得了一些研究成果，但是还是缺少一套准确、完整的对云计算服务产品的评估体系。

2 云计算服务产品的评估体系建立

本文提出了云计算服务产品评估体系的框架模型（见图 1），其整体思路是以传统信息系统安全体系为基础，参考云计算环境安全检查的相关标准，确定基本框架和检查云计算服务产品的指标项。模型根据指标项进行评分，通过分数累计来评判云计算服务产品是否处于优势。此外，该评估体系并不局限于云计算服务器的云端安全，还包括与其相关的其他层面的难度，以此来确定云计算服务器的最终水平。

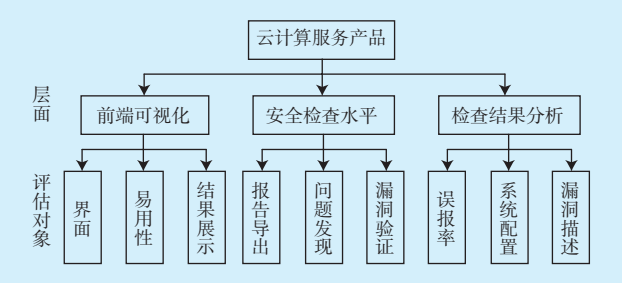


图 1 评估体系模型

Fig.1 Evaluation system model

2.1 安全检查指标

在安全检查方面，根据 CSA 给出的七大风险，不难看出其中每一个风险对企业都具有毁灭性威胁，因此云计算服务产品检查的指标须基于这七大风险来设定。

通过对以上 7 个方面的风险进行总结，可以将其大致归纳为技术风险、管理风险和法律风险 3 个主要风险，其中技术风险的分类根据对象的不同而不同，对象通常是用户和供应商，用户存在的风险有假冒风险、共享风险、数据安全风险、客户端隐私风险、网络传输风险等；供应商存在的风险有服务器风险、服务连续性风险、设备迁移风险等；管理风险主要包括管理人员风险、安全责任风险、管理操作风险等；法律风险主要包括信息泄露的取证、被攻击取证、数据丢失取证等。

以上主要是针对云计算服务器进行的安全检查，但在实际的评估指标中也存在多个风险可能会

(C)1994-2018 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

组成一个指标的情况，同时也会有相对其他方面并非重要的风险可以被忽略，如此考虑是为了简化评估框架，增加评估指标的可用性。

2.2 评估体系框架的建立及权重的确定

评估体系的建立分为 2 级。第 1 级为前端可视化、安全检查水平、检查结果分析 3 个层面。第 2 级为具体的评估对象，其中前端可视化在第 2 级中分为界面、易用性、结果展示；安全检查水平分为报告导出、问题发现、漏洞验证；检查结果分析分为误报率、系统配置、漏洞描述。

评估体系在给出各个风险之后，需要对各个风险指标进行权重确定，假设在层面和评估对象上，第 i 个层面上的第 j 个评估对象所占的权重记作 α_{ij}，其中 i=1，2，3，j=1，2，3，在第 i 个层面上所占据的权重，记作 β_i，故对于第 i 个层面中的各个评估对象 α_{ij} 与 β_i 之间的关系为：

$$\beta_i=\alpha_{i1}+\alpha_{i2}+\alpha_{i3,}\ i=1,2,3 \tag{1}$$

对于不同层面的权重之和有如下关系：

$$\beta_1+\beta_2+\beta_3=1 \tag{2}$$

可以将其写为数学形式：

$$\begin{bmatrix}1 & 1 & 1\end{bmatrix}\begin{bmatrix}\beta_1\\ \beta_2\\ \beta_3\end{bmatrix}=1 \tag{3}$$

假设：

$$\boldsymbol{B}=\begin{bmatrix}\beta_1\\ \beta_2\\ \beta_3\end{bmatrix} \tag{4}$$

称 $\boldsymbol{B}$ 为层面评估向量，另设 $\boldsymbol{I}^{\mathrm{T}}$=[1　1　1]，则(3)式可以简化为：

$$\boldsymbol{I}^{\mathrm{T}}\boldsymbol{B}=1 \tag{5}$$

将(1)式带入到(2)式中，可得：

$$\begin{bmatrix}1 & 1 & 1\end{bmatrix}\begin{bmatrix}\alpha_{11} & \alpha_{12} & \alpha_{13}\\ \alpha_{21} & \alpha_{22} & \alpha_{23}\\ \alpha_{31} & \alpha_{32} & \alpha_{33}\end{bmatrix}\begin{bmatrix}1\\ 1\\ 1\end{bmatrix}=1 \tag{6}$$

假设：

$$\boldsymbol{A}=\begin{bmatrix}\alpha_{11} & \alpha_{12} & \alpha_{13}\\ \alpha_{21} & \alpha_{22} & \alpha_{23}\\ \alpha_{31} & \alpha_{32} & \alpha_{33}\end{bmatrix} \tag{7}$$

称 $\boldsymbol{A}$ 为评估对象权重矩阵，则(6)式可以简化为：

$$\boldsymbol{I}^{\mathrm{T}}\boldsymbol{A}\boldsymbol{I}=1 \tag{8}$$

所以，$\boldsymbol{\beta}_1$ 表示在前端可视化层面上各个评估对象的集合，$\boldsymbol{\beta}_2$ 表示在安全检查水平层面上各个评估对象的集合，$\boldsymbol{\beta}_3$ 表示在检查结果分析层面上各个评估对象的集合，评估体系中各风险指标权重如表 1 所示。

表 1 评估体系各风险指标权重

Table 1 The weight of each risk index values

层面	前端可视化			安全检查水平			检查结果分析		
	β_1			β_2			β_3		
评估对象	界面	易用性	结果展示	报告导出	问题发现	漏洞验证	误报率	系统配置	漏洞描述
	α_{11}	α_{12}	α_{13}	α_{21}	α_{22}	α_{23}	α_{31}	α_{32}	α_{33}

3 实验评估

根据上文建立的云计算服务产品的评估指标模型，选择 A、B、C、D 4 家云服务商的产品进行对比测试。

3.1 测试云计算服务产品

选取 A、B、C、D 4 家云服务商的产品进行对比测试，其中 A、B、C 产品平台界面形式分别如图 2、图 3 及图 4 所示。

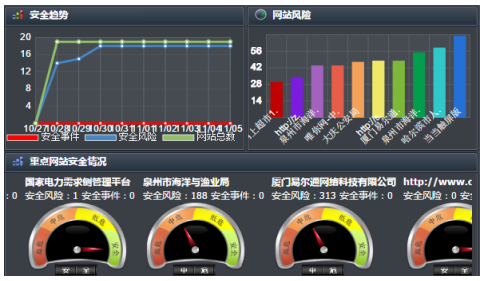


图 2 A 厂商明鉴网站安全检测平台

Fig.2 The security detection platform of A



图 3 B 厂商大规模网站监测系统

Fig.3 The security detection platform of B



图 4 C 厂商网站监测系统

Fig.4 The security detection platform of C

电力信息通信

(C)1994-2019 China Academic Journal Electronic Publishing House. All rights reserved.　http://www.cnki.net

3.2 对比测试结果

在选取 4 个测试的平台之后，再选择 16 个已知的网站，使用不同的测试平台对其进行漏洞扫描和实时监测，得到测试结果。其中 16 个已知网站的标号如表 2 所示，测试结果如表 3 所示。

表 3 中横线部分表示该网站屏蔽了扫描 IP，产品无法对其进行扫描，表中空白部分表示在检测过程中，产品未出现此类风险，表 3 的检测结果将影响各个产品在评估模型中的最终分数。

表 2 网站序号及名称

Table 2 The serial number and the name of Web

序号	网站	序号	网站
1	http://www.xinhuanet.cn	9	http://www.onlyou.com
2	http://www.qzofa.cn	10	http://gaj.daqing.gov.cn
3	http://www.qzhy.gov.cn	11	http://sxb.nea.gov.cn
4	http://zfcg.fjqz.gov.cn:80	12	http://www.cepc.com.cn
5	http://www.weibo.com	13	http://www.nw.sgcc.com.cn
6	http://www.hrblss.gov.cn	14	http://dsm.sx.sgcc.com.cn
7	http://www.harbin.gov.cn	15	http://www.caej.com.cn
8	http://www.12T.CN	16	http://www.hl.sgcc.com.cn

3.3 确定权重矩阵

根据第 2 部分的评估体系模型，需先确定权重矩阵，再对选取的 A、B、C 及 D 4 家云服务厂商的产品进行评分比较。对于评估对象权重矩阵 $\boldsymbol{A}$，给出形式如下：

$$\boldsymbol{A}=\begin{bmatrix}0.15 & 0.10 & 0.10\\ 0.05 & 0.20 & 0.15\\ 0.10 & 0.05 & 0.10\end{bmatrix}$$

根据权重矩阵，整体分数设置为 100 分，故对于每一项的最高分数 $\boldsymbol{K}_{\max}$ 如下：

$$\boldsymbol{K}_{\max}=100\boldsymbol{A}=\begin{bmatrix}15 & 10 & 10\\ 5 & 20 & 15\\ 10 & 5 & 10\end{bmatrix}$$

3.4 评估结果

根据评估体系模型对每一个评估对象的评分结果如表 4 所示。从表 4 中可看出，A 厂商总分为 91 分，位列第一，其余依次为 B 厂商为 90 分、D 厂商为 75 分、C 厂商为 69 分，其中 A 厂商与 B 厂商产品得分相差不大。

在问题发现和漏洞验证方面，A 厂商和 B 厂商单项得分最高，表明在其检测系统的检测下，发现网站存在的问题多，漏洞发现的数量多，相对利于对云计算漏洞的检测。此外，在界面和结果展示方面，A 厂商有较大优势，在图 2 中可以看到，其界面简洁明了，采用仪表盘的方式可以很清楚地将结果展示出来。在其他几个方面，4 款产品的表现大致相同，并未有明显差别。根据第 3 部分建立的评估体系的模型，产生的推荐产品为 A 厂商和 B 厂商。

对于该评估的结果，仅对云计算服务产品评估提供建议，并希望通过该建议来丰富对云计算服务

表 3 各产品的检测结果

Table 3 The detection results of different platforms

网站序号	A 厂商				B 厂商				C 厂商			D 厂商		
	高	中	低	变更	高	中	低	变更	高	中	低	高	中	低
1			41	26			1	16			1		4	
2	5		40	27	13	1	67	4	5	5	9	10	5	1
3	12		212	524	8	2	143	48	4	5	9	6	20	1
4	16		129		2	1	15		2	22	1	3	216	2
5			9		1	2					1		2	
6	9		183	8	5		7	55		1	16	4	102	1
7			7	2 000			780	100						
8	5		247		2		125		2	1	8	4	9	
9	15	4	69		21		243	202		14		7	181	
10	—	—	—	397	96		761	31	1	1	2	6	13	1
11	5	8	139		12		83							
12	8		203		12		421			3	12	14	117	
13			107	30			333	92				1	395	1
14	—	—	14	4			5	23				2	48	
15				1	1	1	1 016						1	
16			15			1	221					1	6	

表 4 评估结果

Table 4 Evaluation results

指标项	A 厂商	B 厂商	C 厂商	D 厂商
界面	15	12	8	12
易用性	8	10	8	8
结果展示	10	9	7	6
报告导出	4	5	0	4
问题发现	18	20	14	18
漏洞验证	15	12	10	10
误报率	9	9	9	6
系统配置	5	5	5	4
漏洞描述	7	8	7	7
总分	91	90	69	75

(C)1994-2018 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

产品的安全检查与评估方面的研究内容，给予更多可能性的帮助，以完善该方面的研究。

4 结语

本文依据国内外现有的对云计算服务产品的安全检查与评估体系的研究，提出了一套云计算服务产品的评估体系模型，并且使用该模型对 4 款产品进行测试与评估。结果显示，在 4 款产品中，A 厂商和 B 厂商的评分比 C 厂商和 D 厂商的评分要高，故根据该模型建议选择 A 厂商和 B 厂商的产品。该模型的提出丰富了云计算的评估内容，同时也促进了云计算服务产品评估的发展。

参考文献：

[1] 龚强. 国外云计算发展现状综述[J]. 信息技术, 2013, 37(6): 1-3.
GONG Qiang. Review of the development situation of cloud computing abroad[J]. Information Technology, 2013, 37(6): 1-3.

[2] 陈兴蜀, 罗永刚, 罗锋盈. 国家标准GB/T 31167—2014《信息安全技术云计算服务安全指南》解读与实施[M]. 北京: 科学出版社, 2014.

[3] 周亚超, 左晓栋.《云计算服务安全能力要求》国家标准解析[J]. 信息技术与标准化, 2014, 56(8): 58-61.
ZHOU Yachao, ZUO Xiaodong. Interpretation of national standard “security capability requirements of cloud computing services” [J]. Information Technology & Standardization, 2014, 56(8): 58-61.

[4] 章恒, 禄凯. 构建云计算环境的安全检查与评估指标体系[J]. 信息网络安全, 2014(9): 115-119.
ZHANG Heng, LU Kai. Building security check and risk assessment index system on cloud computing environment[J]. Netinfo Security, 2014(9): 115-119.

[5] 吴齐跃, 王永琦. 云计算环境下信息安全等级保护测评研究[J]. 中国教育信息化, 2016(11): 13-17.
WU Qiyue, WANG Yongqi. Research on information security classification protection in cloud computing environment[J]. The Chinese Journal of ICT in Education, 2016(11): 13-17.

[6] 王希忠, 王建立, 黄俊强. 云计算环境下等级保护测评[J]. 信息技术, 2015, 39(7): 184-186.
WANG Xizhong, WANG Jianli, HUANG Junqiang. Grade protection evaluation environment under cloud computing[J]. Information Technology, 2015, 39(7): 184-186.

[7] 刘明焕. 基于云计算的风险评估技术研究[J]. 网络安全技术与应用, 2015, 15(6): 74.

[8] 沈余锋, 余小军. 云计算环境下虚拟化安全探讨[J]. 电力信息与通信技术, 2013, 11(11): 6-11.
SHEN Yufeng, YU Xiaojun. Study of virtualization security in cloud computing[J]. Electric Power Information and Communication Technology, 2013, 11(11): 6-11.

[9] 曲延盛, 李亮, 严文涛, 等. 云计算环境中旁路攻击防范研究[J]. 电力信息化, 2013, 11(3): 94-97.
QU Yansheng, LI Liang, YAN Wentao, et al. Research on side channel attack defense in cloud computing[J]. Electric Power Information Technology, 2013, 11(3): 94-97.

[10] 冯扬. 云安全技术研究[J]. 电力信息与通信技术, 2014, 12(1): 22-27.
FENG Yang. Research on cloud security technologies[J]. Electric Power Information and Communication Technology, 2014, 12(1): 22-27.

[11] HEISER J, NICOLETT M. Assessing the security risks of cloud computing[R]. San Diego: Gartner, 2008.

[12] ARCHER J. Top threats to cloud computing V1.0[R]. San Francisco: Cloud Security Alliance, 2010.

[13] ALLIANCE C S. The Notorious Nine: Cloud computing top threats in 2013[R]. San Francisco: Cloud Security Alliance, 2013.

[14] FENG D G, MIN Z, YAN Z, et al. Study on cloud computing security[J]. Journal of Software, 2011, 162(1): 388-396.

[15] NIST 800-144: Guidelines on security and privacy in public cloud computing[S]. Washington: National Institute of Standards and Technology, 2011.

[16] NIST 800-53: Security and privacy control for federal information systems and organizations[S]. Washington: National Institute of Standards and Technology, 2011.

编辑 张钦芝
收稿日期：2018–09–12


李凌

作者简介：
李凌（1979–），女，高级工程师，从事电力行业网络信息安全工作；
郭旭（1983–），男，工程师，从事电力行业网络信息安全工作；
李琳（1994–），女，工程师，从事电力行业网络信息安全工作，xintong-lilin@epri.sgcc.com.cn。

(C)1994-2019 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net